

Submitted by: VARUN.S

DEPT AND SEC: CSE - L

REGISTER NUMBER: RA2511003020700

OWASP Juice Shop Vulnerability Assessment

Cybersecurity Assignment-Task 1

1.Introduction

OWASP Juice Shop is an intentionally vulnerable web application used for cybersecurity training and security testing. In this task, several vulnerabilities were identified and demonstrated in a controlled local environment. The completed challenges included SQL Injection, Cross-Site Scripting (XSS), Score Board Exposure, and Confidential Document Exposure.

2.SQL Injection

Vulnerability: SQL Injection

Description: SQL Injection occurs when untrusted user input is incorporated into a database query without proper protection. In the Juice Shop login challenge, a specially crafted input was used to bypass the normal authentication process.

Risk: An attacker may be able to bypass authentication and gain unauthorized access to application accounts or information.

Prevention:

Use parameterized queries.

Use prepared statements.

Validate and handle user input appropriately.

Avoid constructing SQL queries directly from user input.

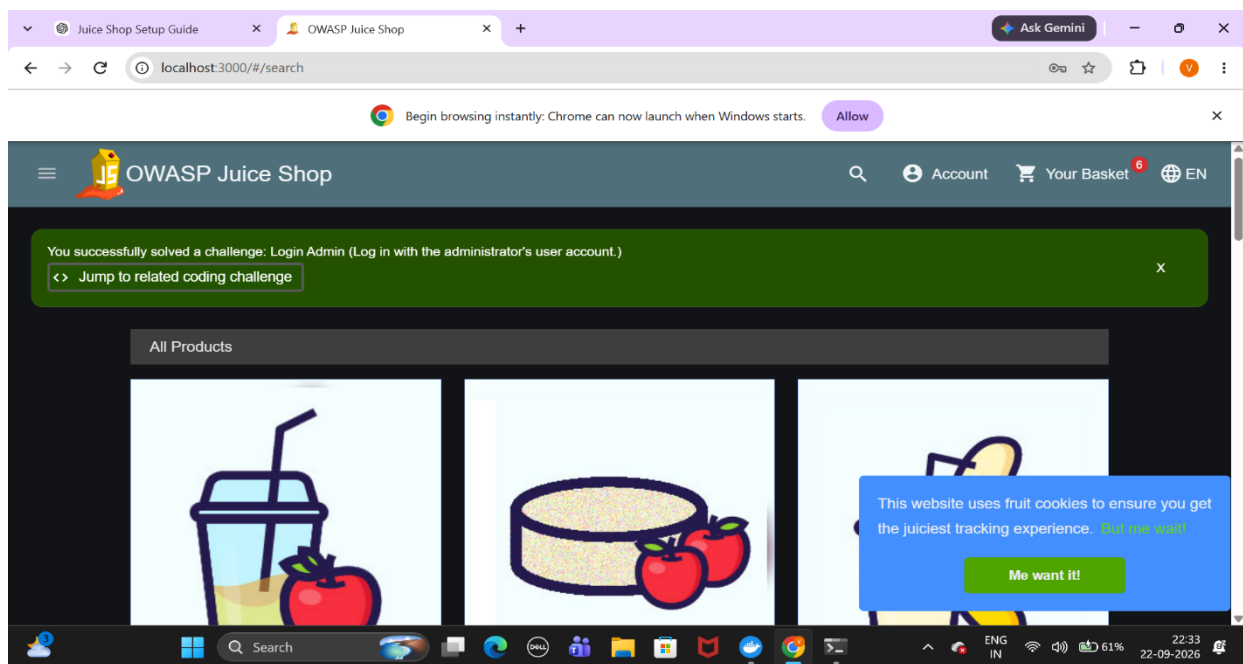


Figure 1:SQL Injection login challenge successfully completed.

3.Cross-Site Scripting (XSS)

Vulnerability: Cross-Site Scripting (XSS)

Description: Cross-Site Scripting occurs when an application processes attacker-controlled content in a way that allows JavaScript to execute in a user's browser. In this challenge, a test XSS payload was entered into the Juice Shop search function and successfully executed.

Risk: XSS can allow malicious scripts to execute in a user's browser and potentially manipulate application content or access information available to the affected web application.

Prevention:

Perform appropriate output encoding.

Sanitize untrusted input where appropriate.

Use a suitable Content Security Policy (CSP).

Apply context-aware input handling.

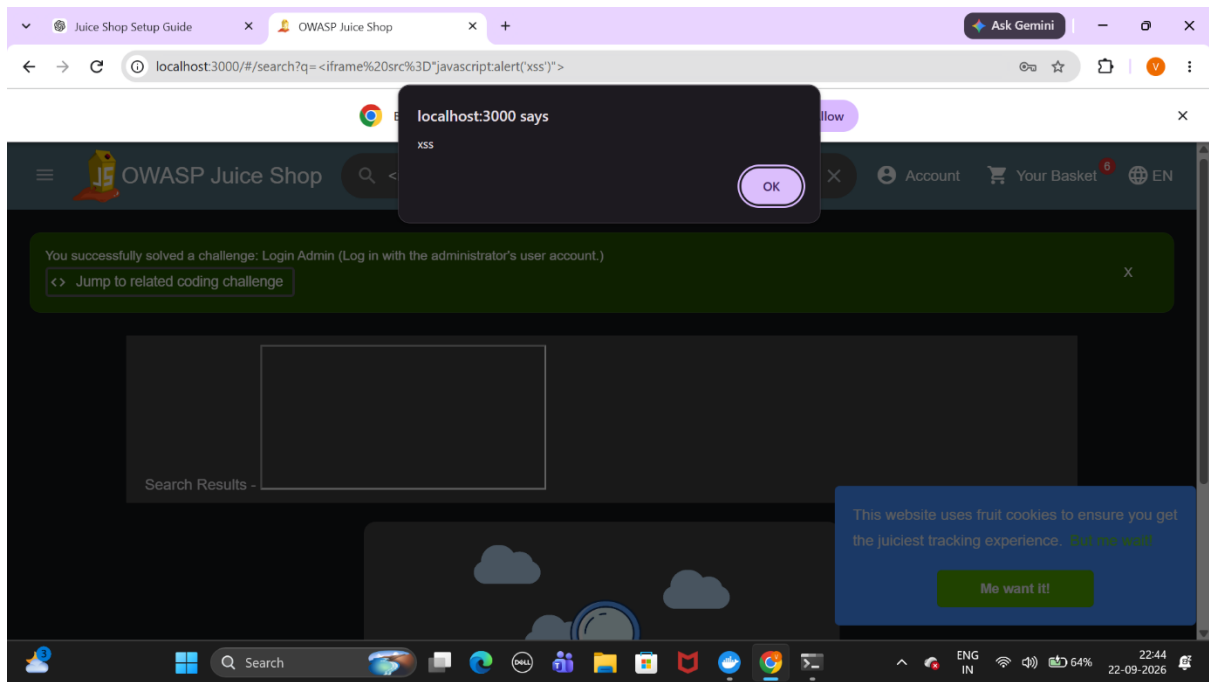


Figure 2:XSS payload successfully executed and displayed an alert.

4.Score Board Exposure

Vulnerability: Broken Access Control / Information Disclosure

Description: The Juice Shop Score Board functionality was accessed through the application. The challenge was successfully completed and the application displayed the corresponding success notification.

Risk: Improperly protected application functionality or information may be accessible to users who should not have access to it.

Prevention:

Implement proper authorization checks.

Enforce access control on the server side.

Ensure that sensitive functionality is available only to authorized users.

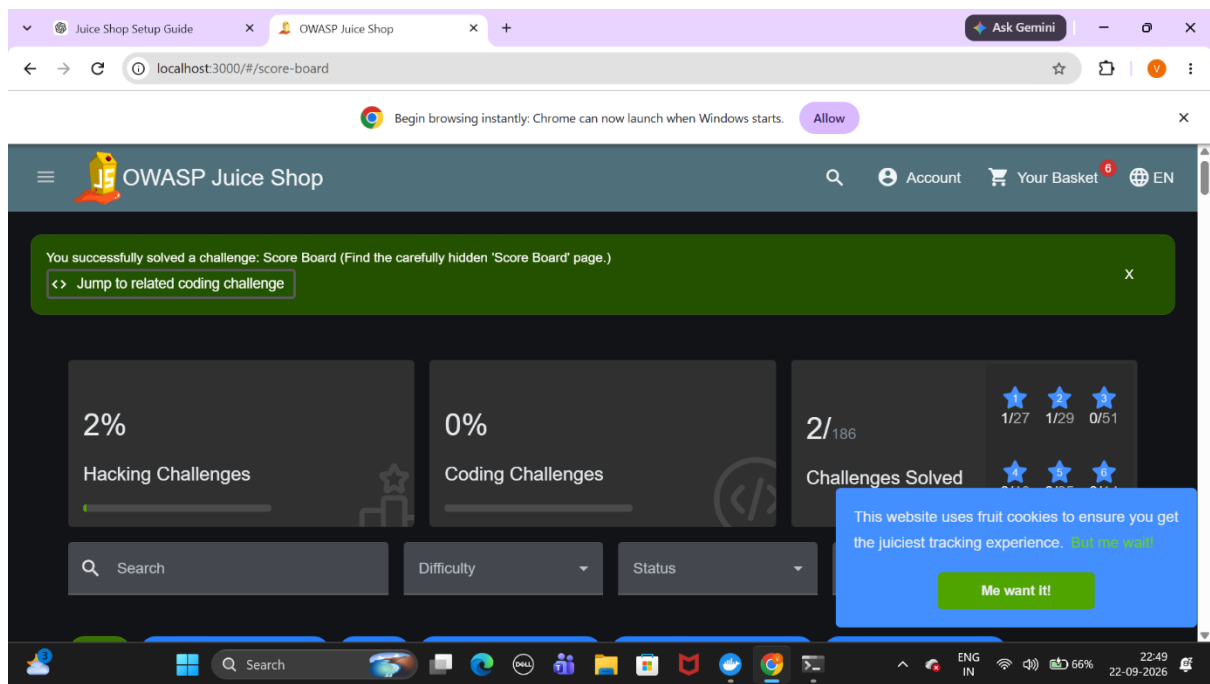


Figure 3: Score Board challenge successfully completed

5. Confidential Document Exposure

Vulnerability: Sensitive Information Disclosure

Description: The Juice Shop application exposes files through its FTP-related functionality. A document available through the exposed location was accessed as part of the challenge.

Risk: Exposed documents may contain confidential company information and could be accessed by unauthorized users.

Prevention:

Restrict access to sensitive files.

Require appropriate authentication and authorization.

Apply secure file and directory permissions.

Do not expose confidential documents through publicly accessible locations.

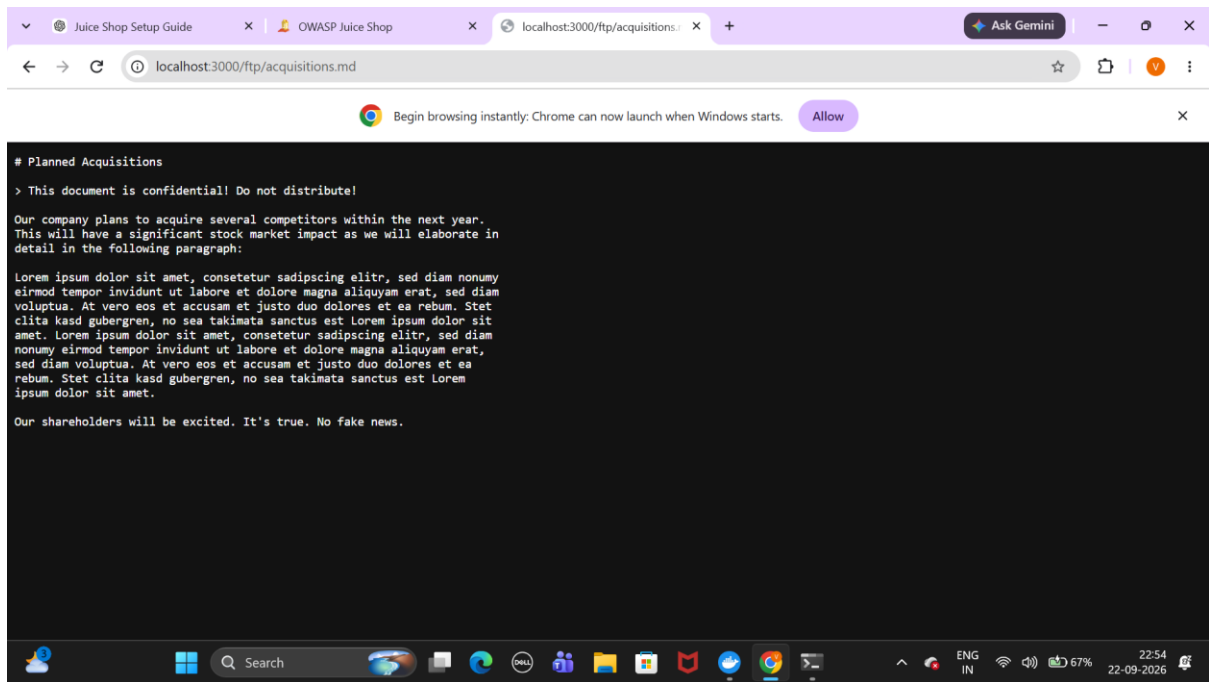


Figure 4: Confidential document accessed through the exposed file location

6.Summary

This exercise demonstrated several common web application security vulnerabilities using the OWASP Juice Shop training environment. The completed challenges covered SQL Injection, Cross-Site Scripting, Score Board Exposure, and Sensitive Information Disclosure. The exercise demonstrated the importance of secure input handling, output encoding, authentication and authorization controls, and proper protection of sensitive files. These security controls can help reduce the risk of unauthorized access and exploitation of web applications.